

System Hardening (Defensive Meeting) (Fall Semester)

Google Def: the process of securing an IT infrastructure by reducing its “attack surface”. It involves removing unnecessary software, disabling unused services, closing open ports, and strictly enforcing the principle of least privilege.

notes on the meeting itself

this outline has been designed to create a more interactive meeting, lots of labs, call and response questions, and interesting explanations to keep the crowds attention.

At the end of this meeting everyone should be able to complete at least most of a cyber patriot style, find and fix box that we setup.

Slide Layout:

- title
- what does “hardening” mean?
 - reducing attack surface
 - removing unnecessary risks
- real world parallel
 - locking doors and windows in a house makes it more secure. If you don’t want someone to break into your house, you close and lock the doors and windows. If you leave all the windows open there is a good chance someone will break in. Every enabled feature, extra piece of software, and open port is another open window in your house.
- what is “attack surface”?
 - the total sum of all potential entry points, vulnerabilities, and methods that an attacker can use to gain access to a system.
 - examples of attack surface (ask the audience for answers first)
 - open ports
 - installed software
 - browser extensions
 - user accounts
 - running services
 - weak passwords

Lab 001

- find the attack surface
- this lab is not meant to be very long.
- the users aren’t sure how to handle anything just yet, but they can look through the OS and figure out what they are up against. We can ask questions like: how many startup programs are there? What are some programs that should not be installed?
 - windows
 - review settings
 - installed apps

- filled with bloatware
- startup programs
 - also bloatware
- task manager
 - have some bloatware processes running, and maybe even a virus or some sort of malware. Not real malware, but something to appear as such for the sake of the meeting.
- services
- Linux
 - same as window just the Linux version.

Slide Layout:

- Updates and Patches
 - why does my computer want to update so often?
 - bugs fixes
 - vulnerabilities have been found
 - what are CVEs?
 - cool stats
 - 32% of all cyberattacks start with an unpatched outdated software vulnerability.
 - On average an unsupported piece of software accumulates 218 new vulnerabilities every six months after official support ends.
- weak passwords
 - weak passwords
 - why are we using weak passwords in the big 26?
 - America's Cyber Defense Agency says:
 - at least 16 characters long or longer
 - use a random string of mixed-case letters, numbers and symbols
 - cXmnZK65rf*&DaaD
 - or create a memorable phrase 4 to 7 unrelated words.
 - HorsePurpleHatRun
 - make them unique
 - use a different password for each account
 - use a password manager
 - enable MFA
 - password reuse
 - don't do this
 - no matter how strong your password is, it will more than likely be leaked from a company breach. If you have the same password for all your accounts, no matter the length, they will compromise all your accounts.
 - credential stuffing or spraying
 - when breaches happen, bad actors will use scripts and bots to attempt logins on massive lists of websites, fishing for a correct set of creds.
 - password managers
 - bitwarden
 - proton pass

- apple's passwords
- DO NOT USE BROWSERS PASSWORD MANAGER
- MFA
 - multi factor authentication
 - this is very important

- least privilege
- what is least privilege?
 - a security principle that a system should restrict the access privileges of users (or processes acting on behalf of users) to the minimum necessary to accomplish assigned tasks.

- real world examples
 - a cashier at Walmart should be able to open the cash register but not alter the store's shipping manifest, or change the companies insurance plan.

- administrator vs user
 - according to least privilege very few people should have administrator access to a machine, when hardening a system ensure only the specified persons are admins.

- firewall
 - what does a firewall do?
 - checks incoming and outgoing data against a set of predetermined rules.
 - incoming data
 - outgoing data
 - ports
 - connections
 - having a firewall is not the same as having an antivirus
 - ensuring that both windows defender, and windows defender firewall are running is very important. Show images of what menus should look like if everything is work as it should.

- software
 - only download software from official sources, downloading pirated, cracked, or stolen software significantly raises the chances of installing malware.
 - avoid sketchy browser extensions
 - remove any software that is not being used or doesn't look legit
 - digital signatures
 - hashes

- supply-chain attacks
- backups
 - if working on a machine that is holding valuable or essential information, it is critical to constantly backup your machine to a secure drive, on a setup machine. This way in case of Ransomware, drive failure, accidental deletion, or whatever else. You still have the data.

Find and Fix:

- windows

Resources

Password Rules: <https://www.cisa.gov/secure-our-world/use-strong-passwords>

Least Privilege: https://csrc.nist.gov/glossary/term/least_privilege